Análise de arquivo suspeito

Share

codigo.py
198 lines

PY

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Revisando as medidas de contenção e os canais de denúncia

Veredito: é malware, com altíssima confiança. O arquivo é um instalador furtivo de extensão para o Google Chrome no Windows. Ele coloca no navegador, sem que o usuário saiba ou aprove, uma extensão baixada de um servidor externo e avisa o atacante quando dá certo. Fiz apenas uma análise estática (li o código, nada foi executado). Vou me limitar ao detalhe necessário para justificar o veredito e orientar a defesa: não vou destrinchar a técnica nem ajudar a ajustar ou melhorar esse tipo de código.

Passo a passo, em linhas gerais: o script começa encerrando os processos do Chrome para mexer na configuração do navegador sem interferência. Em seguida, baixa um ZIP de `antiddos-protection[.]net` (um domínio genérico com nome de "proteção anti-DDoS", e não a Chrome Web Store) e o extrai numa pasta temporária. Em vez de instalar a extensão pelos meios normais, em que o usuário vê e aceita as permissões, ele a grava direto no arquivo `Secure Preferences` do perfil do Chrome. A extensão já entra com acesso a cookies, abas, armazenamento e injeção de scripts em todos os sites, inclusive em janelas anônimas. Para o Chrome não perceber a adulteração, o código forja as assinaturas de integridade que o próprio navegador usa para validar esse arquivo e ainda ativa o modo desenvolvedor. Por fim, envia o nome de usuário da vítima e o ID da extensão para um tópico público do ntfy.sh (`ntfy.sh/crimeorganizado000000000000caiunoob`), que funciona como aviso ao operador de que mais uma máquina foi comprometida.

O que fecha o veredito é a combinação desses elementos:

- instalação oculta e sem consentimento;
- burla deliberada das proteções do Chrome;
- permissões típicas de roubo de cookies e sessões e de manipulação de páginas;
- carga hospedada em domínio enganoso;
- telemetria para o atacante.

Software legítimo usa a Web Store ou políticas corporativas, não isso. As docstrings "Teste de algo novo" e "Novo testes" sugerem uma versão em desenvolvimento, mas o código já é funcional, então isso não atenua nada. Uma ressalva: o conteúdo do ZIP remoto não está no arquivo, então o que a extensão faz exatamente é dedução a partir das permissões. E,

por ser um script em texto, um antivírus que não acuse nada não prova que seja inofensivo.

Se isso chegou a rodar em alguma máquina, considere comprometidas as sessões e contas acessadas naquele navegador. Em ambiente corporativo, acione a equipe de segurança antes de mexer em qualquer coisa. Em `chrome://extensions`, remova qualquer extensão desconhecida ou "não empacotada" e desligue o modo desenvolvedor se não foi você quem o ativou. Depois, a partir de um dispositivo limpo (ou só após a remoção), troque as senhas importantes e encerre todas as sessões ativas, porque cookies roubados permitem sequestrar contas mesmo com verificação em duas etapas. Vale também uma varredura completa com antivírus e descobrir como o script foi parar ali. Para bloqueio e denúncia, os indicadores são o domínio (escrito com `[.]` para evitar cliques acidentais) e o tópico do ntfy acima.

Se quiser, posso ajudar com um checklist de resposta a incidente ou com o texto de uma denúncia de abuso para o provedor do domínio e para o ntfy.sh.

Qual é a categoria principal deste malware?

Escolhendo as técnicas do ATT&CK que se encaixam ▸

Categoria principal: dropper/instalador de extensão maliciosa de navegador, também conhecido como *browser extension hijacker* ou injetor de extensão, com provável objetivo final de **infostealer** (roubo de cookies e sessões).

Este arquivo em si não rouba nada. Seu papel é entregar a carga: baixa a extensão de um servidor externo, a instala à força no perfil do Chrome contornando as proteções do navegador e avisa o operador. Por isso ele é um dropper/loader com comportamento de sequestro de navegador.

O que a extensão faz depois não está no arquivo. As permissões que o script concede (cookies, abas, scripting, acesso a todos os sites e a janelas anônimas) apontam para roubo de sessões e possível manipulação de páginas, como em trojans bancários com web-inject, mas isso é inferência, não algo confirmado.

Também não se encaixa em outras categorias comuns. Não é ransomware nem worm (não se propaga), e não é um RAT completo, já que o único canal de comunicação visível aqui é uma notificação de mão única via ntfy.sh.

Para fins de classificação em frameworks, o comportamento se alinha com ATT&CK T1176 (Browser Extensions), T1105 (Ingress Tool Transfer), T1562 (Impair Defenses, pela adulteração das verificações de integridade do Chrome) e, como objetivo provável, T1539 (Steal Web Session Cookie).